

Quantification du risque de non-conformité DORA

Le modèle, où j'en suis, et quatre demandes d'appui

Kélian Kaddouri

ENSAE / Nexialog Consulting

10 août 2026

Les cinq piliers, et la question que je pose

Le règlement DORA impose cinq familles d'exigences sur le risque informatique. Je les traite comme **cinq composantes de maîtrise** qui peuvent défaillir, et surtout s'entraîner.

P_1 Gouvernance	qui décide, qui est responsable, quels moyens
P_2 Incidents	détecter, escalader, répondre, notifier
P_3 Tests	tester avant mise en service, corriger, renouveler les clés
P_4 Tiers	fournisseurs, sous-traitance, dépendance externe
P_5 Partage	recevoir et faire circuler les alertes sur les menaces

La question, en une phrase

Deux entités peuvent avoir *les mêmes* faiblesses et ne pas porter le même risque, parce que ce qui compte est **quelle faiblesse entraîne quelle autre**. Une gouvernance défaillante qui provoque des tests insuffisants n'a pas le même coût que l'inverse. C'est cela que je cherche à quantifier, et c'est ce qu'une charge forfaitaire ne peut pas voir.

Trois briques, et où la cascade agit

1. La fréquence : combien d'incidents par an

Binomiale négative pilotée par un facteur systémique commun, calibrée à 21,56 incidents informatiques matériels par an pour le secteur financier mondial. Pour descendre à une entité, j'estime le taux comme une **fonction de la taille** de firme, log-actifs en covariable, élasticité 0,0744, et je lis la courbe au bon endroit plutôt que de prendre une tranche.

2. La sévérité : combien coûte une défaillance de pilier

Dépassements de seuil et Pareto généralisée au-delà de $u = 20,03$ M€, sur 91 excès : $\hat{\xi} = 0,5954$. Cette valeur dit déjà beaucoup : **au-dessus de 0,5 la variance est infinie, en dessous de 1 l'espérance existe encore**. Le quantile extrême est donc porté par un sinistre unique, pas par une accumulation.

La troisième brique est l'**agrégation**, et c'est là que se situe l'apport : je ne couple pas les marges par une copule, je modélise la propagation. Deux slides pour la formule, puis une pour ce qu'elle fait à la perte. Sources : scripts 07, 47, 60 et 63.

La formule retenue : un Vasicek multivarié à contagion retardée

Le stress latent du pilier j , pour l'entité i à la période t

$$X_{ij,t} = \text{base}_j + \sum_{k \neq j} W_{kj} D_{ik,t-1} + s_j Y_{j,t} + \varepsilon_{ij,t}, \quad D_{ij,t} = \mathbf{1}\{X_{ij,t} \geq 0\}$$

Quatre termes : le **seuil**, la **contagion dirigée retardée**, le **systémique** du pilier, l'**idiosyncratique**. L'incident est le franchissement du seuil, et un incident sur k relève le stress de j de W_{kj} , la ligne k étant celle qui *émet*.

D'où sort s_j , et pourquoi ce n'est pas un objet nouveau

Même décomposition systémique / idiosyncratique qu'un Vasicek, **réécrite dans les unités de l'estimation** : l'incident ne dépendant que du *signe* de X , on renormalise pour mettre le coefficient de ε à 1, puisqu'on estime par probit. D'où

$$s_j = \sqrt{\frac{\rho_j}{1 - \rho_j}}, \quad \rho_j = \frac{s_j^2}{1 + s_j^2}.$$

s_j est donc $\sqrt{\rho_j}$ en unités idiosyncratiques, les deux paramétrages sont en **bijection**, et base_j est le seuil déplacé du côté du stress.

W, sa normalisation, et deux criticités à ne pas confondre

W en une phrase, et sa normalisation

W_{jk} est la force dirigée de j vers k : **la ligne émet, la colonne reçoit**. Une matrice 5×5 , diagonale nulle, **non symétrique**, c'est tout l'objet.

$$W(g) = g \frac{T}{\max_j \sum_k T_{jk}}, \quad g \in (0, 1]$$

T porte la structure, g l'amplitude, le diviseur est l'**émission maximale**, 2,60, celle de P_1 . Chaque ligne somme alors à au plus g : le pilier le plus prolifique engendre **au plus** g descendants directs, exactement 0,90 à $g = 0,90$. Donc **g se lit comme le nombre de dominos qu'un domino fait tomber**, et la stabilité est gratuite.

Sources : scripts 03 et 59.

Ce que la cascade fait à la perte, et deux criticités

Elle ne majore rien, elle compte des piliers

C'est le point à retenir. Un incident **démarre** à un pilier, puis se propage. La cascade ne multiplie aucune perte par un coefficient : elle détermine **combien de piliers sont touchés**, et la perte de l'incident est la *somme* des sévérités des piliers touchés. Un incident qui touche trois piliers coûte trois tirages de sévérité, pas un.

Deux rayons spectraux, et c'est la confusion que j'ai évitée

La contagion portant sur des incidents, l'objet qui gouverne l'extinction n'est plus W mais la **matrice de génération suivante** : $M_{kj} = \Phi(\text{base}_j + W_{kj}) - \Phi(\text{base}_j)$, la probabilité d'un incident en j si k a frappé, moins l'incidence de fond de 4,5 %.

- $\rho(W) = 0,506$ gouverne le système latent *simultané*, la forme abandonnée ;
- $R_0 = \rho(M) = \mathbf{0,054}$ gouverne la **cascade d'incidents** : c'est le R_0 des épidémiologistes, et c'est lui qui compte.

Les deux sont sous-critiques, mais pas du même ordre : seuils à $g = 1,78$ et $g = 8,1$, hors du domaine. La forme simultanée est donc **structurellement alarmiste**, raison de plus de l'avoir écartée.

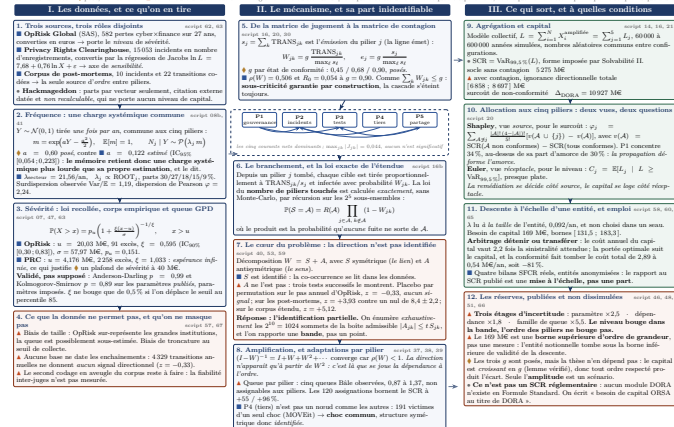
D'où l'abandon de la forme simultanée : même normalisée, elle approche son seuil critique cinq fois plus vite que la cascade réelle, donc elle est **structurellement alarmiste**. Le prix d'une jolie formule fermée aurait été une exigence de capital surévaluée. Sources : scripts 03 et 29.

Le modèle en un schéma, et le statut de chaque grandeur

Quantifier le besoin de capital DORA : de la donnée brute au capital, puis à son allocation

■ estimée sur données ♦ posée, non calibrée ▲ bornée faute d'identification

● réglementaire ou standard chaque bloc est un choix atteignable séparément, et chaque nombre est imprimé par le script indiqué à droite.



Chaque grandeur porte une pastille de statut : **estimée**, **posée**, **bornée** faute d'identification, ou **réglementaire**, pour qu'on puisse attaquer le modèle bloc par bloc.

Ce que la donnée dit de W , et ce qu'elle ne dit pas

La difficulté, et elle est structurelle

Toute matrice se décompose de façon unique en $W = S + A$, S symétrique et A antisymétrique. Or une base d'incidents enregistre que deux piliers ont défailli *ensemble*, jamais **lequel a cédé le premier** : elle identifie S , la co-occurrence, et **pas** A , qui est exactement la direction. Sur la paire P_1-P_3 je sais combien de fois les deux ont lâché, pas dans quel ordre.

Le choix : borner plutôt que trancher arbitrairement

La positivité impose $|A_{jk}| \leq S_{jk}$, ce qui définit un pavé de matrices admissibles. Je n'en choisis pas une : j'**énumère** ses $2^{10} = 1\,024$ **sommets** et je publie l'ensemble des valeurs compatibles. C'est de l'identification partielle, au sens de Manski.

Ce que cela donne, et pourquoi c'est un résultat

Socle sans aucune propagation 5 275 M€, bornes [6 858 ; 8 697]. Je peux donc dire que la propagation ajoute au socle, et de combien au plus et au moins, **sans prétendre savoir de combien exactement**. La largeur de la bande mesure précisément ce que la donnée ignore.

Sources : scripts 30 et 31.

Comment j'ai quand même estimé la direction

Les bases agrégées ne donnant pas l'ordre, je suis allé le chercher là où il est écrit : dans les **rapports d'enquête publics**, qui reconstituent la séquence des défaillances.

	P_1	P_2	P_3	P_4	P_5
Émission (somme de la ligne de T)	2,60	1,50	1,40	1,70	0,70
Réception (somme de la colonne)	0,80	2,30	1,60	1,50	1,70

P_1 émet le plus et reçoit le moins, c'est une **source** ; P_2 reçoit le plus, c'est un **puits**. Cette structure était un jugement ; le corpus la retrouve.

Le dispositif, et le test

Dix rapports officiels codés en 22 transitions dirigées, codées seulement si le rapport *établit* que j a précédé et conditionné k . Sous l'hypothèse nulle n'y a pas de direction $\hat{z}$, l'orientation de chaque transition est un tirage à pile ou face : cette loi nulle est **exacte**, par convolution sur les paires, sans simulation. $p = 1,5 \cdot 10^{-5}$.

La limite que je me suis opposée moi-même

Un rapport cherche une *cause racine*, et « défaillance de gouvernance » est une conclusion de convention : **onze des vingt-deux transitions partent de P_1** . J'ai mesuré ce qu'il faudrait pour me contredire, et **aucun nombre de retraits ne suffit** : en supprimant les onze arêtes de P_1 , donc la moitié du corpus, la direction reste significative ($p = 0,0039$) sur les chaînes $P_3 \rightarrow P_2$ et $P_4 \rightarrow P_2$.

Sources : scripts 59 et 64.

Ce que le point du 7 août a produit

Trois choses, dont deux corrections de fond.

Une confusion d'échelles, levée

Je présentais sous la même étiquette un quantile de **sévérité**, sur un sinistre unique, et un besoin de capital, sur la **charge annuelle agrégée** : cela fait lire une différence d'échelle comme une incohérence, et la séance a buté là. Le vocabulaire est séparé et le passage d'une échelle à l'autre est calculé. Ce qui ferme la question : le rapport entre les deux **s'inverse selon l'échelle**, donc aucun rapport fixe ne les relie.

Le statut de la mesure de queue, précisé

Faut-il fonder le capital sur une espérance conditionnelle de queue plutôt que sur un quantile ? L'argument qui tranche n'est pas le degré de prudence mais l'**existence** : sur ma seconde source de sévérité, $\hat{\xi} = 1,033 > 1$, donc **la mesure n'est pas définie**. Je l'utilise en diagnostic, jamais en couverture.

Une comparaison retirée, et la calibration gelée

Je rapportais mon résultat à la charge forfaitaire de Formule Standard. J'ai retiré cette comparaison : le rapport varie d'un facteur cinquante selon la composition du bilan, donc son **niveau** ne mesure rien. Reste que le forfait est **identique quel que soit l'état de maîtrise** là où le modèle les écarte. Depuis, la calibration est gelée.

Sources : scripts 63, 65 et 67.

Demande 1 : quelle posture reporter

Votre remarque était le point de départ, et je vous rends le résultat tel qu'il est. Intégrer l'incertitude *avant* de prendre le quantile ne déplace presque pas le point : 645 contre 657, écart moyen de 5 M€ pour un bruit de 7. Ce qui était fragile était la **largeur** : de 411 à 1 037 M€. Votre remarque tenait, mais pas par le mécanisme attendu : elle condamne le quantile *cité seul*.

Posture	Ce qu'elle intègre	Niveau	bruit
Point (<i>plug-in</i>)	rien : quantile d'un ajustement ponctuel	657	—
Prédictive	l'incertitude de paramètre, <i>avant</i> le quantile	645	± 7
Robuste $\beta = 90\%$	borne haute sur l'ambiguïté de paramètre	939	± 13
Robuste $\beta = 95\%$	idem, prudence plus élevée	1 037	± 9
Robuste $\beta = 99\%$	idem, et la plus bruitée des six	1 247	± 24
Pire-cas de modèle	on ajoute l'ambiguïté de <i>famille</i> ($\xi = 0,90$)	1 331	—

En M€. **Les deux extrémités sont exactes**, ne comportant aucune simulation : tout le bruit est au milieu, donc une posture plus riche est moins reproductible. Et **la plus prudente est la moins précise**.

Ma question, et c'est la seule qui appelle une décision de votre part

Je reporte aujourd'hui le **plug-in avec sa bande**. Faut-il plutôt reporter la **prédictive**, plus honnête sur l'estimation et sans coût en niveau ? Passer au **robuste 95 %** multiplierait le résultat par 1,6 : cela relève d'une politique prudentielle, et je ne pense pas que ce soit à moi de le décider seul.

Sources : scripts 46, 47 et 51.

Demandes 2 à 4 : trois questions de méthode

2. Ma sévérité n'est pas plafonnée quand je descends à une entité

L'élasticité de la sévérité à la taille vaut 0,087, intervalle $[0,026 ; 0,148]$, donc **très proche de zéro à sa borne basse**. Le modèle affirme donc qu'une entité de quelques milliards subit à peu près la sévérité d'une institution mondiale. D'où une **borne inférieure de taille** sous laquelle la transposition n'est plus crédible. Le correctif que je vois, un plafond adossé à l'exposition propre, déplacerait tous mes résultats d'entité et je suis en gel de calibration. **Peut-on borner ce biais sans recalibrer ?**

3. Mon capital est un capital de queue

La base est tronquée à son seuil de collecte : la composante **attritionnelle** en est absente, par absence d'observation et non par choix. Deux atténuations : le quantile est porté par un sinistre unique, et à l'échelle d'une entité 98,8 % des années sont sans incident matériel. Je déclare la limite avec son sens, elle sous-estime, sans chiffrer sa taille. **Suffisant, ou faut-il reconstruire la partie tronquée ?**

4. Mon intervalle de confiance est trop étroit

La couverture réelle de mon intervalle à 90 % sur l'indice de queue vaut 86 % : l'incertitude sur ξ est **sous-estimée**, d'environ 10 % en demi-largeur. Je l'ai signalé plutôt que corrigé. **Correction reconnue, ou publier la sous-couverture ?**

Sources : scripts 47, 57, 60 et 65.

Si le temps le permet : comment la conformité entre dans le modèle

Un point non trivial, qui emprunte à votre logique d'états de conformité.

La conformité n'ajoute pas une pénalité, elle déplace quatre paramètres

Passer de l'état conforme à l'état non conforme ne surcharge le capital d'aucun terme additionnel : cela déplace la **fréquence** de 21,6 à 53,6, le **taux de détection** de 0,128 à 0,181, le **gain de propagation** g de 0,45 à 0,90, et un terme d'**accumulation** de 0 à 0,68.

Et ces quatre canaux ne s'additionnent pas

Pris isolément ils somment à 9 138 M€ quand l'écart total vaut 14 139 : +5 001 M€ **d'interaction, soit +35 %**. La propagation est super-additive, ce qui interdit d'additionner des leviers de remédiation pour chiffrer un plan partiel. Deux canaux sont calibrables, la fréquence et la détection ; les deux autres sont *bornés*.

Un point qui ne dépend pas de moi. Le corpus de rapports qui identifie la direction de W est codé par un seul lecteur, moi. La fiabilité inter-juges attend un **second codage en aveugle** : dix récits, une heure, kit prêt, et cela ne demande pas un expert du domaine. Auriez-vous un nom à me suggérer ? Sources : scripts 20, 43 et 54.